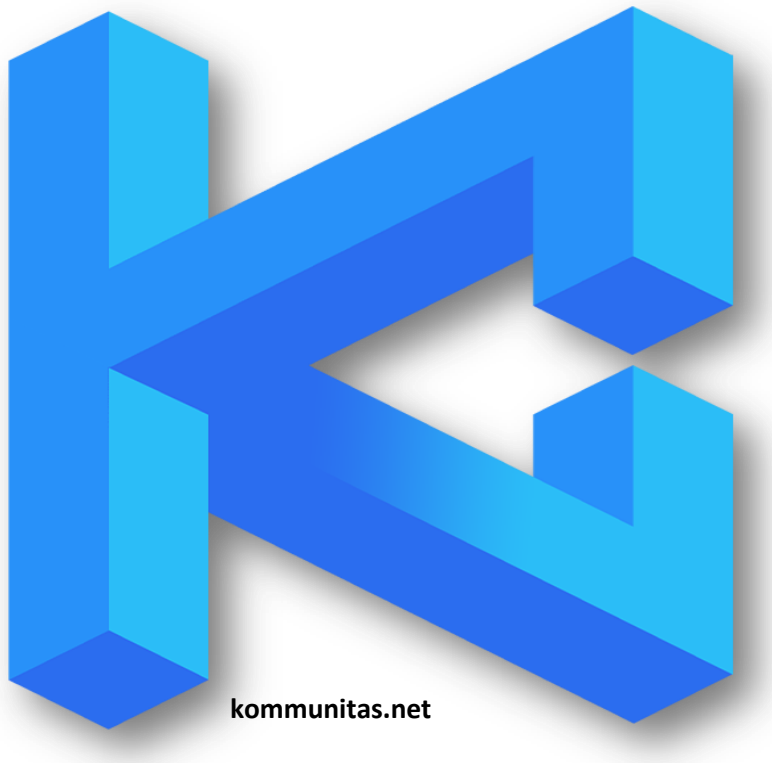

Target Site: https://kommunitas.net

Server: Cloudflare

Server technologies: PHP

Table of Contents

Executive Summary **03**

OWASP Top 10 ..... **03**

Assessment Methodology **04**

Manual Application Testing **04**

Criteria for Risk Ratings **06**

Issues By Risk Factor **06**

High-Risk Findings **07**

H1. WordPress debug mode 07

H2. WordPress Plugin WebARX Cross-Site Scripting (1.3.0) 09

Medium-Risk Findings **10**

M1. Application error messages 10

M2. Directory listings 13

M3. Source code disclosures 15

Low-Risk Findings **17**

L1. Documentation files 17

L2. Insecure Inline Frame (iframe) 20

L3. Possible sensitive directories 21

L4. TLS/SSL certificate about to expire 23

L5. WordPress admin accessible without HTTP authentication 24

L6. Cookies with missing, inconsistent, or contradictory properties 25

Conclusion **34**

Executive Summary:

The primary goal of this web application penetration testing project was to identify any potential areas related to the application in your current state and to determine how much the system could be compromised by an attacker with certain skills and motivations. It has been evaluated according to the "Best-in-Class" method as defined by the Entrance Test Guidance for the Open Web Application Security Project (OWASP).

OWASP Top 10

The table below summarizes the findings for OWASP's Top 10 list for web application vulnerabilities. OWASP Top 10 represents the list of the most critical web application security flaws, which are accompanied by OWASP security experts from around the world. The list provides a powerful awareness document for web application security and is utilized within many security standards:

1. **Injection**
   Injection flaws, such as SQL, NoSQL, OS, and LDAP injection, occur when untrusted data is sent to an interpreter as part of a command or query. The attacker's hostile data can trick the interpreter into executing unintended commands or accessing data without proper authorization.
2. **Broken Authentication**
   Application functions related to authentication and session management are often implemented incorrectly, allowing attackers to compromise passwords, keys, or session tokens, or to exploit other implementation flaws to assume other users' identities temporarily or permanently.
3. **Sensitive Data Exposure**
   Many web applications and APIs do not properly protect sensitive data, such as financial, healthcare, and PII. Attackers may steal or modify such weakly protected data to conduct credit card fraud, identity theft, or other crimes. Sensitive data may be compromised without extra protection, such as encryption at rest or in transit, and requires special precautions when exchanged with the browser.

4. **XML External Entities (XXE)**
   Many older or poorly configured XML processors evaluate external entity references within XML documents. External entities can be used to disclose internal files using the file URI handler, internal file shares, internal port scanning, remote code execution, and denial of service attacks.
5. **Broken Access Control**
   Restrictions on what authenticated users are allowed to do are often not properly enforced. Attackers can exploit these flaws to access unauthorized functionality and/or data, such as

access other users' accounts, view sensitive files, modify other users' data, change access rights, etc.

6. **Security Misconfiguration**
   Security misconfiguration is the most commonly seen issue. This is commonly a result of insecure default configurations, incomplete or ad hoc configurations, open cloud storage, misconfigured HTTP headers, and verbose error messages containing sensitive information. Not only must all operating systems, frameworks, libraries, and applications be securely configured, but they must be patched/upgraded in a timely fashion.
7. **Cross-Site Scripting (XSS)**
   XSS flaws occur whenever an application includes untrusted data in a new web page without proper validation or escaping, or updates an existing web page with user-supplied data using a browser API that can create HTML or JavaScript. XSS allows attackers to execute scripts in the victim's browser which can hijack user sessions, deface websites, or redirect the user to malicious sites.
8. **Insecure Deserialization**
   Insecure deserialization often leads to remote code execution. Even if deserialization flaws do not result in remote code execution, they can be used to perform attacks, including replay attacks, injection attacks, and privilege escalation attacks.
9. **Using Components with Known Vulnerabilities**
   Components, such as libraries, frameworks, and other software modules, run with the same privileges as the application. If a vulnerable component is exploited, such an attack can facilitate serious data loss or server takeover. Applications and APIs using components with known vulnerabilities may undermine application defenses and enable various attacks and impacts.
10. **Insufficient Logging & Monitoring**
    Insufficient logging and monitoring, coupled with missing or ineffective integration with incident response, allows attackers to further attack systems, maintain persistence, pivot to more systems, and tamper, extract, or destroy data. Most breach studies show time to detect a breach is over 200 days, typically detected by external parties rather than internal processes or monitoring.

Assessment Methodology

I have created this report based on the results and Solutions described in this report on application vulnerability scans and manual penetration tests conducted against the application.

Manual Application Testing

Using data generated by automated testing software, I have also employed manual testing techniques to identify and attempt additional vulnerabilities in targeted applications and to eliminate false positives produced by automated scanning processes. This assessment is in line with best-practice practices

defined by methods such as ISCOM's Open Source Security Testing Methodology Manual (OSSMM) and Open Web Application Security Project (OWSP).

I performed the following actions as part of this test:

- The gathered information about the application
- Mapped application content and analyzed it
- Observed types and placement of security controls
- Reviewed web page HTML source code for possible vulnerabilities
- Tested application authentication, session management, and access controls
- Tested application for client data validation issues
- Tested application for input-based vulnerabilities
- Tested application for business logic flaws
- Checked for application server vulnerabilities

The test focused on possible vulnerabilities in the application logic, looking for issues including but not limited to:

- SQL and command injection
- Cross-site scripting
- Cross-site request forgery
- Authentication and authorization implementation defects
- Access control issues and privilege elevation
- Session management/hijacking
- File input-output implementation defects
- Parameter overflow and handling
- HTTP/URL manipulation
- Application logic defects
- Improper web server configuration
- Concurrency issues
- Information leakage
- SSL and transport layer weaknesses
- Application-level denial-of-service

Criteria for Risk Ratings

The table below outlines the general rules for assigning risk ratings to identified vulnerabilities:

Risk Rating	Description
HIGH	These issues identify conditions that could directly result in the compromise or unauthorized access of a network, system, application, or sensitive information. Examples of High-Risk issues include remote execution of commands, known buffer overflows; unauthorized access, and disclosure of sensitive information.
MEDIUM	These issues identify conditions that do not immediately or directly result in the compromise or unauthorized access of a network, system, application of information but do provide a capability or information that could, in combination with other capabilities or information, result in the compromise or unauthorized access of a network, application or information. Examples of Medium Risk issues include directory browsing, partial access to files on the system; disclosure of security mechanisms, and unauthorized use of services.
LOW	These issues identify conditions that do not immediately or directly result in compromise of a network, system, application, or information but do provide information that could be used in combination with other information to gain insight into how to compromise or gain unauthorized access to a network, system, application or information.
INFORMATIONAL	The issue has been fixed since the previous round of penetration testing.

Issues By Risk Factor

High	2
Medium	3
Low	6

High-Risk Findings

H1. WordPress debug mode

Risk Rating: High

Affected Functionality:

- https://kommunitas.net/wp-content/debug.log

Pattern found:

[17-May-2021 15:41:16 UTC] PHP Notice: Trying to get property 'ID' of non-object in /home/u176981514/domains/kommunitas.net/public_html/wp-content/plugins/all-in-one-seo-pack/app/Common/Meta/Title.php on line 103

Description:

During the development of plugins or themes, as well as during the deployment of a WordPress site, developers or system administrators may enable debug logs to log any PHP errors that occur.

WordPress makes use of the WP_DEBUG constant which is defined in wp-config.php. The constant is used to trigger the debug mode throughout WordPress. The constant is set to be false by default.

On this website, WordPress debug mode is enabled. When debug mode is enabled all PHP notices, warnings, errors, and other debugging information are logged in a file named ./wp-content/debug.log. This file is readable by anybody who has access to this website. An attacker can use the debugging information from this file to conduct further attacks.

Impact:

Possible sensitive information disclosure.

Solution:

The most important PHP constant that can be used to enable debugging mode on your site is WP_DEBUG.

By default, this PHP constant is set to false. It will be shown as follows in your wp-config.php file.

```
define( 'WP_DEBUG', false );
```

In order to turn on logging, all you need to do is to set WP_DEBUG to true.

See the code below.

kommunitas.net

define('WP_DEBUG', true);

Below are a couple of things, you'll need to keep in your mind before enabling WordPress to debug.

- Be careful before making any changes to your wp-config.php file because it is the most important file in your installation that can be used to configure database access, enhance performance and improve security. Making a small mistake in the configuration can result in your site becoming inaccessible.
- Make sure you don't enable WordPress debugging on a live site. As I said before, crucial information can be revealed, besides the fact that leaving WordPress debugging enabled will create performance problems because it results in significant overhead.

Recommend Reading: How to backup WordPress natively or with a plugin!

Now that we've enabled the setting for WordPress debugging we'll need to look at the output of the debugging commands. To do this, it is best that we enable the WordPress debugging log file.

This can be done by enabling the next setting in wp-config.php.

Proof of Concept:

```
[17-May-2021 15:41:16 UTC] PHP Notice:  Trying to get property 'ID' of non-object in /home/u176981514/domains/kommunitas.net/public_html/wp-content/plugins/all-in-one-seo-
pack/app/Common/Meta/Title.php on line 103
[17-May-2021 15:41:16 UTC] PHP Notice:  Trying to get property 'ID' of non-object in /home/u176981514/domains/kommunitas.net/public_html/wp-content/plugins/all-in-one-seo-
pack/app/Common/Meta/Title.php on line 114
[17-May-2021 15:41:16 UTC] PHP Notice:  Trying to get property 'post_type' of non-object in /home/u176981514/domains/kommunitas.net/public_html/wp-content/plugins/all-in-one-seo-
pack/app/Common/Meta/Title.php on line 119
[17-May-2021 15:41:16 UTC] PHP Notice:  Trying to get property 'ID' of non-object in /home/u176981514/domains/kommunitas.net/public_html/wp-content/plugins/all-in-one-seo-
pack/app/Common/Meta/Title.php on line 119
[17-May-2021 15:41:16 UTC] PHP Notice:  Trying to get property 'ID' of non-object in /home/u176981514/domains/kommunitas.net/public_html/wp-content/plugins/all-in-one-seo-
pack/app/Common/Meta/Title.php on line 122
[17-May-2021 15:41:16 UTC] PHP Notice:  Trying to get property 'ID' of non-object in /home/u176981514/domains/kommunitas.net/public_html/wp-content/plugins/all-in-one-seo-
pack/app/Common/Meta/Title.php on line 123
[17-May-2021 15:41:16 UTC] PHP Notice:  Trying to get property 'ID' of non-object in /home/u176981514/domains/kommunitas.net/public_html/wp-content/plugins/all-in-one-seo-
pack/app/Common/Meta/Description.php on line 104
[17-May-2021 15:41:16 UTC] PHP Notice:  Trying to get property 'post_type' of non-object in /home/u176981514/domains/kommunitas.net/public_html/wp-content/plugins/all-in-one-seo-
pack/app/Common/Meta/Description.php on line 124
[17-May-2021 15:41:16 UTC] PHP Notice:  Trying to get property 'ID' of non-object in /home/u176981514/domains/kommunitas.net/public_html/wp-content/plugins/all-in-one-seo-
pack/app/Common/Meta/Description.php on line 124
[17-May-2021 15:41:16 UTC] PHP Notice:  Trying to get property 'post_excerpt' of non-object in /home/u176981514/domains/kommunitas.net/public_html/wp-content/plugins/all-in-one-seo-
pack/app/Common/Meta/Description.php on line 129
[17-May-2021 15:41:16 UTC] PHP Notice:  Trying to get property 'ID' of non-object in /home/u176981514/domains/kommunitas.net/public_html/wp-content/plugins/all-in-one-seo-
pack/app/Common/Meta/Description.php on line 138
[17-May-2021 15:41:16 UTC] PHP Notice:  Trying to get property 'post_content' of non-object in /home/u176981514/domains/kommunitas.net/public_html/wp-content/plugins/all-in-one-seo-
pack/app/Common/Meta/Description.php on line 139
[17-May-2021 15:41:16 UTC] PHP Notice:  Trying to get property 'ID' of non-object in /home/u176981514/domains/kommunitas.net/public_html/wp-content/plugins/all-in-one-seo-
pack/app/Common/Meta/Description.php on line 153
[17-May-2021 15:41:16 UTC] PHP Notice:  Trying to get property 'ID' of non-object in /home/u176981514/domains/kommunitas.net/public_html/wp-content/plugins/all-in-one-seo-
pack/app/Common/Meta/Description.php on line 153
[17-May-2021 15:41:16 UTC] PHP Notice:  Trying to get property 'ID' of non-object in /home/u176981514/domains/kommunitas.net/public_html/wp-content/plugins/all-in-one-seo-
pack/app/Common/Meta/Description.php on line 154
[17-May-2021 15:41:16 UTC] PHP Notice:  Trying to get property 'ID' of non-object in /home/u176981514/domains/kommunitas.net/public_html/wp-content/plugins/all-in-one-seo-
pack/app/Common/Meta/Title.php on line 103
[17-May-2021 15:41:16 UTC] PHP Notice:  Trying to get property 'ID' of non-object in /home/u176981514/domains/kommunitas.net/public_html/wp-content/plugins/all-in-one-seo-
pack/app/Common/Meta/Title.php on line 104
[17-May-2021 15:41:16 UTC] PHP Notice:  Trying to get property 'ID' of non-object in /home/u176981514/domains/kommunitas.net/public_html/wp-content/plugins/all-in-one-seo-
pack/app/Common/Meta/Description.php on line 104
[17-May-2021 15:41:16 UTC] PHP Notice:  Trying to get property 'ID' of non-object in /home/u176981514/domains/kommunitas.net/public_html/wp-content/plugins/all-in-one-seo-
pack/app/Common/Meta/Description.php on line 105
```

kommunitas.net

```
[14-Jun-2021 07:31:29 UTC] PHP Warning:  mysqli_real_connect(): (HY000/1226): User 'u176981514_gL5kR' has exceeded the 'max_user_connections' resource (current value: 50) in
/home/u176981514/domains/kommunitas.net/public_html/wp-includes/wp-db.php on line 1653
[14-Jun-2021 07:31:29 UTC] PHP Warning:  mysqli_real_connect(): (HY000/1226): User 'u176981514_gL5kR' has exceeded the 'max_user_connections' resource (current value: 50) in
/home/u176981514/domains/kommunitas.net/public_html/wp-includes/wp-db.php on line 1653
[14-Jun-2021 07:31:29 UTC] PHP Warning:  mysqli_real_connect(): (HY000/1226): User 'u176981514_gL5kR' has exceeded the 'max_user_connections' resource (current value: 50) in
/home/u176981514/domains/kommunitas.net/public_html/wp-includes/wp-db.php on line 1653
[14-Jun-2021 07:31:29 UTC] PHP Warning:  mysqli_real_connect(): (HY000/1226): User 'u176981514_gL5kR' has exceeded the 'max_user_connections' resource (current value: 50) in
/home/u176981514/domains/kommunitas.net/public_html/wp-includes/wp-db.php on line 1653
[14-Jun-2021 07:31:29 UTC] PHP Warning:  mysqli_real_connect(): (HY000/1226): User 'u176981514_gL5kR' has exceeded the 'max_user_connections' resource (current value: 50) in
/home/u176981514/domains/kommunitas.net/public_html/wp-includes/wp-db.php on line 1653
[14-Jun-2021 07:31:29 UTC] PHP Warning:  mysqli_real_connect(): (HY000/1226): User 'u176981514_gL5kR' has exceeded the 'max_user_connections' resource (current value: 50) in
/home/u176981514/domains/kommunitas.net/public_html/wp-includes/wp-db.php on line 1653
[14-Jun-2021 07:31:29 UTC] PHP Warning:  mysqli_real_connect(): (HY000/1226): User 'u176981514_gL5kR' has exceeded the 'max_user_connections' resource (current value: 50) in
/home/u176981514/domains/kommunitas.net/public_html/wp-includes/wp-db.php on line 1653
[14-Jun-2021 07:31:29 UTC] PHP Warning:  mysqli_real_connect(): (HY000/1226): User 'u176981514_gL5kR' has exceeded the 'max_user_connections' resource (current value: 50) in
/home/u176981514/domains/kommunitas.net/public_html/wp-includes/wp-db.php on line 1653
[14-Jun-2021 07:31:29 UTC] PHP Warning:  mysqli_real_connect(): (HY000/1226): User 'u176981514_gL5kR' has exceeded the 'max_user_connections' resource (current value: 50) in
/home/u176981514/domains/kommunitas.net/public_html/wp-includes/wp-db.php on line 1653
[14-Jun-2021 07:31:29 UTC] PHP Warning:  mysqli_real_connect(): (HY000/1226): User 'u176981514_gL5kR' has exceeded the 'max_user_connections' resource (current value: 50) in
/home/u176981514/domains/kommunitas.net/public_html/wp-includes/wp-db.php on line 1653
[14-Jun-2021 07:31:29 UTC] PHP Warning:  mysqli_real_connect(): (HY000/1226): User 'u176981514_gL5kR' has exceeded the 'max_user_connections' resource (current value: 50) in
/home/u176981514/domains/kommunitas.net/public_html/wp-includes/wp-db.php on line 1653
[14-Jun-2021 07:31:29 UTC] PHP Warning:  mysqli_real_connect(): (HY000/1226): User 'u176981514_gL5kR' has exceeded the 'max_user_connections' resource (current value: 50) in
/home/u176981514/domains/kommunitas.net/public_html/wp-includes/wp-db.php on line 1653
[14-Jun-2021 07:31:29 UTC] PHP Warning:  mysqli_real_connect(): (HY000/1226): User 'u176981514_gL5kR' has exceeded the 'max_user_connections' resource (current value: 50) in
/home/u176981514/domains/kommunitas.net/public_html/wp-includes/wp-db.php on line 1653
[14-Jun-2021 07:31:29 UTC] PHP Warning:  mysqli_real_connect(): (HY000/1226): User 'u176981514_gL5kR' has exceeded the 'max_user_connections' resource (current value: 50) in
/home/u176981514/domains/kommunitas.net/public_html/wp-includes/wp-db.php on line 1653
[14-Jun-2021 07:31:29 UTC] PHP Warning:  mysqli_real_connect(): (HY000/1226): User 'u176981514_gL5kR' has exceeded the 'max_user_connections' resource (current value: 50) in
/home/u176981514/domains/kommunitas.net/public_html/wp-includes/wp-db.php on line 1653
[14-Jun-2021 07:31:29 UTC] PHP Warning:  mysqli_real_connect(): (HY000/1226): User 'u176981514_gL5kR' has exceeded the 'max_user_connections' resource (current value: 50) in
/home/u176981514/domains/kommunitas.net/public_html/wp-includes/wp-db.php on line 1653
[14-Jun-2021 07:31:29 UTC] PHP Warning:  mysqli_real_connect(): (HY000/1226): User 'u176981514_gL5kR' has exceeded the 'max_user_connections' resource (current value: 50) in
/home/u176981514/domains/kommunitas.net/public_html/wp-includes/wp-db.php on line 1653
[14-Jun-2021 07:31:29 UTC] PHP Warning:  mysqli_real_connect(): (HY000/1226): User 'u176981514_gL5kR' has exceeded the 'max_user_connections' resource (current value: 50) in
/home/u176981514/domains/kommunitas.net/public_html/wp-includes/wp-db.php on line 1653
[14-Jun-2021 07:31:29 UTC] PHP Warning:  mysqli_real_connect(): (HY000/1226): User 'u176981514_gL5kR' has exceeded the 'max_user_connections' resource (current value: 50) in
/home/u176981514/domains/kommunitas.net/public_html/wp-includes/wp-db.php on line 1653
```

References:

- https://wordpress.org/support/article/debugging-in-wordpress/

H2. WordPress Plugin WebARX Cross-Site Scripting (1.3.0)

Risk Rating: High

Affected Functionality:

- https://kommunitas.net/wp-content/plugins/webarx/readme.txt

Current plugin version: 1.0.7.

Latest plugin version: undefined.

Plugin versions lower (or equal) to 1.3.0 are affected.

Description:

WordPress Plugin WebARX is prone to a cross-site scripting vulnerability because it fails to properly sanitize user-supplied input. An attacker may leverage this issue to execute arbitrary script code in the browser of an unsuspecting user in the context of the affected site. This can allow the attacker to steal cookie-based authentication credentials and launch other attacks. WordPress Plugin WebARX version 1.3.0 is vulnerable; prior versions may also be affected.

Solution:

Edit the source code to ensure that input is properly sanitized or disable the plugin until a fix is available

Proof of Concept:

References:

- https://packetstormsecurity.com/files/149573/WordPress-WebARX-Website-Firewall-4.9.8-XSS-Bypass.html

Medium-Risk Findings

M1. Application error messages

Risk Rating: Medium

Affected Functionality:

- **https://kommunitas.net/wp-content/plugins/all-in-one-seo-pack/vendor_prefixed/psr/log/Psr/Log/Test/TestLogger.php**

  Fatal error

- **https://kommunitas.net/wp-content/plugins/all-in-one-seo-pack/vendor_prefixed/psr/log/Psr/Log/Test/TestLogger.php**

  Fatal error: Uncaught Error: Class 'AIOSEO\Vendor\Psr\Log\AbstractLogger' not found in /home/u176981514/domains/kommunitas.net/public_html/wp-content/plugins/all-in-one-

seo-pack/vendor_prefixed/psr/log/Psr/Log/Test/TestLogger.php:56 Stack trace: #0 {main} thrown in /home/u176981514/domains/kommunitas.net/public_html/wp-content/plugins/all-in-one-seo-pack/vendor_prefixed/psr/log/Psr/Log/Test/TestLogger.php on line 56

Description:

Application error or warning messages may expose sensitive information about an application's internal workings to an attacker.These messages may also contain the location of the file that produced an unhandled exception.

While information disclosure vulnerabilities are not directly exploitable by an attacker, they may help an attacker to learn about system-specific information. The following is a list of some of the information an attacker may be able to obtain from application error disclosure.

- Internal IP addresses
- Secrets (passwords, keys, tokens...)
- Operating system distributions
- Software version numbers
- Missing security patches
- Application stack traces
- SQL statements
- Location of sensitive files (backups, temporary files...)
- Location of sensitive resources (databases, caches, code repositories...)

Impact:

Error messages may disclose sensitive information which can be used to escalate attacks.

Solution:

Instead of showing errors to the user, configure the application properly to log errors in a file and upgrade all upgradable plugins, themes, and WordPress versions.

kommunitas.net

Proof of Concept:

Fatal error: Uncaught Error: Class 'AIOSEO\Vendor\Psr\Log\AbstractLogger' not found in /home/u176981514/domains/kommunitas.net/public_html/wp-content/plugins/all-in-one-seo-pack/vendor_prefixed/psr/log/Psr/Log/Test/TestLogger.php:56 Stack trace: #0 {main} thrown in **/home/u176981514/domains/kommunitas.net/public_html/wp-content/plugins/all-in-one-seo-pack/vendor_prefixed/psr/log/Psr/Log/Test/TestLogger.php** on line **56**

References:

- https://www.php.net/manual/en/errorfunc.configuration.php#ini.display-errors

M2. Directory listings

Risk Rating: Medium

Affected Functionality:

Folders with directory listing enabled:

- https://kommunitas.net/wp-includes/SimplePie/Decode/HTML/

Description:

Directory listing is a web server function that displays the directory contents when there is no index file in a specific website directory. It is dangerous to leave this function turned on for the webserver because it leads to information disclosure.

- The easiest way to disable directory listing is to create an index file. The name of the index file depends on the webserver configuration. On Apache is called index.htm, index.html. On IIS is named default.asp, default.aspx, default.htm.
- On the IIS directory listings are disabled by default.
- For Apache, you need to edit the Apache configuration file (usually named httpd.conf) or create a .htaccess file. In the configuration file, you will have the definition of the directory. Something like <Directory /directoryname/subdirectory> Options Indexes FollowSymLinks ... </Directory> To disable the directory listing for that directory you need to remove the 'Indexes' option.

Impact:

A user can view a list of all files from the affected directories possibly exposing sensitive information.

Solution:

As a security best practice it is recommended to disable directory listing. You can disable directory listing by creating an empty index file (index.php, index.html, or any other extension your web server is configured to parse) in the relevant directory. Though in many cases this is not the best Solution because such files are typically forgotten for example when migrating the web application from development to production environments, or when new directories are added.

So you should implement a permanent and secure Solution by disabling directory listing at the webserver level, as explained in this article.

kommunitas.net

Proof of Concept:

Request

Pretty | Raw | \n | Actions

```
1  GET /wp-content/et-cache/773/ HTTP/2
2  Host: kommunitas.net
3  Cookie: _ga=GA1.2.1270988368.1629172597; _gid=GA1.2.151874741.1629172597
4  Sec-Ch-Ua: "Chromium";v="89", ";Not A Brand";v="99"
5  Sec-Ch-Ua-Mobile: ?0
6  Upgrade-Insecure-Requests: 1
7  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
   Gecko) Chrome/89.0.4389.90 Safari/537.36
8  Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*
   ;q=0.8,application/signed-exchange;v=b3;q=0.9
9  Sec-Fetch-Site: none
10 Sec-Fetch-Mode: navigate
11 Sec-Fetch-User: ?1
12 Sec-Fetch-Dest: document
13 Accept-Encoding: gzip, deflate
14 Accept-Language: en-US,en;q=0.9
15 Connection: close
```

Request | Response

Pretty | Raw | Render | \n | Actions

```
    </head>
21  <body>
22    <h1>
        Index of /wp-content/et-cache/773/
      </h1>
      <pre>
        <img src="/_autoindex/icons/blank.png" alt="      ">
         <a href='?ND'>Name</a>                                                    <a href='?MA'>Last modified</a>
                 <a href='?SA'>Size</a>
          <a href='?DA'>Description</a>
23      <hr>
        <img src="/_autoindex/icons/up.png" alt="up">
         <a href="/wp-content/et-cache/">Parent Directory</a>                 13-Aug-2021 10:33        -
24      <img src="/_autoindex/icons/html.png" alt="[HTM]">
         <a href="/wp-content/et-cache/773/et-core-unified-773-16288430396298.min.css">et-core-unified-773-16288430396298.min.css</a>
                                          13-Aug-2021 08:23       4k
25      <img src="/_autoindex/icons/html.png" alt="[HTM]">
         <a href="/wp-content/et-cache/773/et-core-unified-tb-0-773-16288430396298.min.css">et-core-unified-tb-0-773-16288430396298.min.css</a>
                                         13-Aug-2021 08:24       24k
26      <img src="/_autoindex/icons/html.png" alt="[HTM]">
         <a href="/wp-content/et-cache/773/et-core-unified-vb-773-16288507824068.min.css">et-core-unified-vb-773-16288507824068.min.css</a>
                                         13-Aug-2021 10:33       4k
27      <img src="/_autoindex/icons/html.png" alt="[HTM]">
         <a href="/wp-content/et-cache/773/et-core-unified-vb-tb-0-773-16288507824068.min.css">et-core-unified-vb-tb-0-773-16288507824068.min.css</a>
                                         13-Aug-2021 10:33       4k
28    </pre>
      <hr>
      <address>
        Proudly Served by LiteSpeed Web Server at kommunitas.net Port 443
      </address>
29  </body>
30 </html>
```

Index of /wp-content/et-cache/773/

Name	Last modified	Size	Description
Parent Directory	13-Aug-2021 10:33	-	
et-core-unified-773-16288430396298.min.css	13-Aug-2021 08:23	4k	
et-core-unified-tb-0-773-16288430396298.min.css	13-Aug-2021 08:24	24k	
et-core-unified-vb-773-16288507824068.min.css	13-Aug-2021 10:33	4k	
et-core-unified-vb-tb-0-773-16288507824068.min.css	13-Aug-2021 10:33	4k	

Proudly Served by LiteSpeed Web Server at kommunitas.net Port 443

References:

- https://cwe.mitre.org/data/definitions/548.html

M3. Source code disclosures

Risk Rating: Medium

Affected Functionality:

Pages with source code disclosed:

- https://kommunitas.net/wp-content/plugins/duplicate-page/languages/duplicate-page.po

<?php _e('Duplicate Page Settings', 'duplicate-page')?></h1>

<?php $duplicatepageoptions = array();

msgid "Duplicate Page Settings"

msgstr ""

if(isset($_POST['submit_duplicate_page']) && wp_verify_nonce($_POST['duplicatepage_nonce_field'], 'duplicatepage_action')):

_e("Saving Please wait...", 'duplicate-page');

$needToUnset = array('submit_duplicate_page');//no need to save in Database

msgid "Saving Please wait..."

msgstr ""

if(!empty($msg) && $msg == 1):

_e('

Settings saved. <button class="notice-dismiss" type="button">Dismiss this notice.</button> ', 'duplicate-page');

msgid ""

"<div class=\"updated settings-error notice is-dismissible\" id=\"setting-error-settings_updated\"> \r\n"

" Settings saved. <button class=\"notice-dismiss\" type=\"button\"><span class

kommunitas.net

Description:

The application appears to disclose some server-side source code written in PHP.

Source code intended to be kept server-side can sometimes end up being disclosed to users. Such code may contain sensitive information such as database passwords and secret keys, which may help malicious users formulate attacks against the application.

Impact:

An attacker can gather sensitive information (database connection strings, application logic) by analyzing the source code. This information can be used to conduct further attacks.

Solution:

Server-side source code is normally disclosed to clients as a result of typographical errors in scripts or because of misconfiguration, such as failing to grant executable permissions to a script or directory. Review the cause of the code disclosure and prevent it from happening.

Proof of Concept:

Request

Pretty | Raw | \n | Actions

```
1  GET /wp-content/plugins/duplicate-page/languages/duplicate-page.po HTTP/2
2  Host: kommunitas.net
3  Cookie: _ga=GA1.2.1270988368.1629172597; _gid=GA1.2.151874741.1629172597
4  Sec-Ch-Ua: "Chromium";v="89", ";Not A Brand";v="99"
5  Sec-Ch-Ua-Mobile: ?0
6  Upgrade-Insecure-Requests: 1
7  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
   Gecko) Chrome/89.0.4389.90 Safari/537.36
8  Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*
   ;q=0.8,application/signed-exchange;v=b3;q=0.9
9  Sec-Fetch-Site: none
10 Sec-Fetch-Mode: navigate
11 Sec-Fetch-User: ?1
12 Sec-Fetch-Dest: document
13 Accept-Encoding: gzip, deflate
14 Accept-Language: en-US,en;q=0.9
15 Connection: close
```

kommunitas.net

Request Response

Pretty Raw Render \n Actions

```
33
34 # <div class="wrap duplicate page settings">
35 # <h1><?php _e('Duplicate Page Settings', 'duplicate-page')?></h1>
36 # <?php $duplicatepageoptions = array();
37 msgid "Duplicate Page Settings"
38 msgstr ""
39
40 # if(isset($_POST['submit_duplicate_page']) && wp_verify_nonce( $_POST['duplicatepage_nonce_field'], 'duplicatepage_action' )):
41 # _e("<strong>Saving Please wait...</strong>", 'duplicate-page');
42 # $needToUnset = array('submit_duplicate_page');//no need to save in Database
43 msgid "<strong>Saving Please wait...</strong>"
44 msgstr ""
45
46 # if(!empty($msg) && $msg == 1):
47 # _e( '<div class="updated settings-error notice is-dismissible" id="setting-error-settings_updated">
48 # <p><strong>Settings saved.</strong></p><button class="notice-dismiss" type="button"><span class="screen-reader-text">Dismiss this notice.</span></button></div>', 'duplicate-page');
49 msgid ""
50 "<div class=\"updated settings-error notice is-dismissible\" id=\"setting-error-settings_updated\"> \r\n"
51 "<p><strong>Settings saved.</strong></p><button class=\"notice-dismiss\" type=\"button\"><span class=\"screen-reader-text\">Dismiss this notice.</span></button></div>"
52 msgstr ""
53
54 # elseif(!empty($msg) && $msg == 2):
55 # _e( '<div class="error settings-error notice is-dismissible" id="setting-error-settings_updated">
56 # <p><strong>Settings not saved.</strong></p><button class="notice-dismiss" type="button"><span class="screen-reader-text">Dismiss this notice.</span></button></div>',
   'duplicate-page');
57 msgid ""
58 "<div class=\"error settings-error notice is-dismissible\" id=\"setting-error-settings_updated\"> \r\n"
59 "<p><strong>Settings not saved.</strong></p><button class=\"notice-dismiss\" type=\"button\"><span class=\"screen-reader-text\">Dismiss this notice.</span></button></div>"
60 msgstr ""
61
62 # <tr>
63 # <th scope="row"><label for="duplicate_post_status"><?php _e('Duplicate Post Status', 'duplicate-page')?></label></th>
64 # <td><select id="duplicate_post_status" name="duplicate_post_status">
65 msgid "Duplicate Post Status"
```

References:

- https://cwe.mitre.org/data/definitions/540.html

Low-Risk Findings

L1. Documentation files

Risk Rating: Low

Affected Functionality:

Documentation files:

- **https://kommunitas.net/readme.html**

  File contents (first 100 characters):

  <!DOCTYPE html>

  <html lang="en">

  <head>

  <meta name="viewport" content="width=device-width" />

  <meta ...

kommunitas.net

- **https://kommunitas.net/license.txt**

  File contents (first 100 characters):

  WordPress - Web publishing software

  Copyright 2011-2021 by the contributors

  This program is fr ...

- **https://kommunitas.net/wp-content/themes/Divi/README.md**

  File contents (first 100 characters):

  # Divi Theme

  ![CI](https://github.com/elegantthemes/Divi/workflows/CI/badge.svg) ![Inspections](http ...

- **https://kommunitas.net/wp-content/themes/Divi/changelog.txt**

  File contents (first 100 characters):

  version 4.9.4 (updated 04-13-2021)

  - Fixed search module custom left and right padding not working ...

- **https://kommunitas.net/wp-content/plugins/cookie-notice/readme.txt**

  File contents (first 100 characters):

  === Cookie Notice & Compliance for GDPR / CCPA ===

  Contributors: humanityco

  Tags: gdpr, ccpa, cook ...

Description:

One or more documentation files (e.g. readme.txt, changelog.txt, ...) were found. The information contained in these files could help an attacker identify the web application you are using and sometimes the version of the application. It's recommended to remove these files from production systems.

Impact:

These files may disclose sensitive information. This information can be used to launch further attacks.

Solution:

Remove or restrict access to all documentation files accessible from the internet.

kommunitas.net

Proof of Concept:

Request

Pretty | Raw | \n | Actions

```
1  GET /readme.html HTTP/2
2  Host: kommunitas.net
3  Cookie: _ga=GA1.2.1270988368.1629172597; _gid=GA1.2.151874741.1629172597;
   wordpress_test_cookie=WP%20Cookie%20check; cf_chl_prog=a10
4  Cache-Control: max-age=0
5  Sec-Ch-Ua: "Chromium";v="89", ";Not A Brand";v="99"
6  Sec-Ch-Ua-Mobile: ?0
7  Upgrade-Insecure-Requests: 1
8  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
   Gecko) Chrome/89.0.4389.90 Safari/537.36
9  Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*
   ;q=0.8,application/signed-exchange;v=b3;q=0.9
10 Sec-Fetch-Site: none
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Accept-Encoding: gzip, deflate
15 Accept-Language: en-US,en;q=0.9
16 Connection: close
```

Response:

```
<!DOCTYPE html>
<html lang="en">
  <head>
    <meta name="viewport" content="width=device-width" />
    <meta http-equiv="Content-Type" content="text/html; charset=utf-8" />
    <title>
      WordPress &#8250; ReadMe
    </title>
    <link rel="stylesheet" href="wp-admin/css/install.css?ver=20100228" type="text/css" />
  </head>
  <body>
    <h1 id="logo">
      <a href="https://wordpress.org/"><img alt="WordPress" src="wp-admin/images/wordpress-logo.png" />
      </a>
    </h1>
    <p style="text-align: center">
      Semantic Personal Publishing Platform
    </p>
    <h2>
      First Things First
    </h2>
    <p>
      Welcome. WordPress is a very special project to me. Every developer and contributor adds something unique to the mix, and together we create something beautiful th
    </p>
    <p style="text-align: right">
      &#8212; Matt Mullenweg
```

kommunitas.net

L2. Insecure Inline Frame (iframe)

Risk Rating: Low

Affected Functionality:

An iframe tag references an external resource, and no sandbox attribute is set.

Description:

The web page was found to be using an Inline Frame ("iframe") to embed a resource, such as a different web page. The Inline Frame is either configured insecurely or not as securely as expected. This vulnerability alert is based on the origin of the embedded resource and the iframe's sandbox attribute, which can be used to apply security restrictions as well as exceptions to these restrictions.

Impact:

When a web page uses an insecurely configured iframe to embed another web page, the latter may manipulate the former, and trick its visitors into performing unwanted actions.

Solution:

Review the iframe's purpose and environment, and use the sandbox attribute to secure the iframe while applying sandbox directives to ease security restrictions if necessary.

Proof of Concept:

Request Response

Pretty Raw \n Actions

```
1  GET / HTTP/2
2  Host: kommunitas.net
3  Cookie: _ga=GA1.2.1270988368.1629172597; _gid=GA1.2.151874741.1629172597; wordpress_test_cookie=WP%20Cookie%20check; _usrp_lq=20210928
4  Cache-Control: max-age=0
5  Sec-Ch-Ua: "Chromium";v="89", ";Not A Brand";v="99"
6  Sec-Ch-Ua-Mobile: ?0
7  Upgrade-Insecure-Requests: 1
8  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/89.0.4389.90 Safari/537.36
9  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
10 Sec-Fetch-Site: none
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Accept-Encoding: gzip, deflate
15 Accept-Language: en-US,en;q=0.9
16 Connection: close
```

kommunitas.net

References:

- https://developer.mozilla.org/en-US/docs/Web/HTML/Element/iframe
- https://www.w3.org/TR/html52/semantics-embedded-content.html#element-attrdef-iframe-sandbox
- https://html.spec.whatwg.org/multipage/iframe-embed-object.html#the-iframe-element

L3. Possible sensitive directories

Risk Rating: Low

Affected Functionality:

Possible sensitive directories:

- https://kommunitas.net/wp-content/uploads
- https://kommunitas.net/wp-admin/includes

Description:

More potentially sensitive directories have been found. These resources are not directly linked to the website. This check looks for common sensitive resources such as backup directories, database dumps, administration pages, temporary directories. Each of these directories helps an attacker learn more about his or her goals.

kommunitas.net

Impact:

These directories may expose sensitive information that could help a malicious user to prepare for more advanced attacks.

Solution:

Restrict access to these directories or remove them from the website.

Proof of Concept:

Index of /wp-content/uploads/

Name	Last modified	Size	Description
Parent Directory	09-May-2021 07:52	-	
2021	01-Aug-2021 00:46	-	
et_temp	09-May-2021 07:52	-	
wpforms	09-May-2021 07:47	-	

Proudly Served by LiteSpeed Web Server at kommunitas.net Port 443

Index of /wp-admin/includes/

Name	Last modified	Size	Description
Parent Directory	16-Aug-2021 01:16	-	
admin-filters.php	09-May-2021 07:45	8k	
admin.php	09-May-2021 07:45	4k	
ajax-actions.php	09-May-2021 07:45	144k	
bookmark.php	09-May-2021 07:45	12k	
class-automatic-upgrader-skin.php	09-May-2021 07:45	4k	
class-bulk-plugin-upgrader-skin.php	09-May-2021 07:45	4k	
class-bulk-theme-upgrader-skin.php	09-May-2021 07:45	4k	
class-bulk-upgrader-skin.php	09-May-2021 07:45	8k	
class-core-upgrader.php	09-May-2021 07:45	16k	
class-custom-background.php	09-May-2021 07:45	24k	
class-custom-image-header.php	09-May-2021 07:45	48k	
class-file-upload-upgrader.php	09-May-2021 07:45	4k	
class-ftp-pure.php	09-May-2021 07:45	8k	
class-ftp-sockets.php	09-May-2021 07:45	12k	
class-ftp.php	09-May-2021 07:45	28k	
class-language-pack-upgrader-skin.php	09-May-2021 07:45	4k	
class-language-pack-upgrader.php	09-May-2021 07:45	16k	
class-pclzip.php	09-May-2021 07:45	196k	
class-plugin-installer-skin.php	09-May-2021 07:45	12k	
class-plugin-upgrader-skin.php	09-May-2021 07:45	4k	

L4. TLS/SSL certificate about to expire

Risk Rating: Low

Affected Functionality:

The TLS/SSL certificate (serial: 400175048314a4c8218c84a90c16cddf) will expire in less than 60 days. The certificate validity period is from Thu Oct 08 2020 01:21:40 GMT+0600 (Bangladesh Standard Time) to Thu Sep 30 2021 01:21:40 GMT+0600 (Bangladesh Standard Time) (44 days left)

Description:

One of the TLS/SSL certificates used by your server is about to expire.

Once the certificate has expired, most web browsers will present end-users with a security warning, asking them to manually confirm the authenticity of your certificate chain. Software or automated systems may silently refuse to connect to the server.

This alert is not necessarily caused by the server (leaf) certificate but may have been triggered by an intermediate certificate. Please refer to the certificate serial number in the alert details to identify the affected certificate.

Impact:

If an application server detects an expired certificate with a system it is communicating with, the application server may continue processing data as if nothing happened, or the connection may be abruptly terminated.

Solution:

Contact your Certificate Authority to renew the SSL certificate.

L5. WordPress admin accessible without HTTP authentication

Risk Rating: Low

Description:

It's recommended to restrict access to the WordPress administration dashboard using HTTP authentication. Password protecting your WordPress admin dashboard through a layer of HTTP authentication is an effective measure to thwart attackers attempting to guess user's passwords. Additionally, if attackers manage to steal a user's password, they will need to get past HTTP authentication in order to gain access to the WordPress login form.

Impact:

No impact is associated with this vulnerability.

Solution:

Add server-side password protection (such as BasicAuth) to the /wp-admin/ directory. Consult web references for more information.

Proof of Concept:

Request Response

Pretty Raw \n Actions

```
1  GET /wp-admin/ HTTP/2
2  Host: kommunitas.net
3  Cookie: _ga=GA1.2.1270988368.1629172597; _gid=GA1.2.151874741.1629172597; wordpress_test_cookie=WP%20Cookie%20check; _usrp_lq=20210928
4  Upgrade-Insecure-Requests: 1
5  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/89.0.4389.90 Safari/537.36
6  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
7  Sec-Fetch-Site: none
8  Sec-Fetch-Mode: navigate
9  Sec-Fetch-User: ?1
10 Sec-Fetch-Dest: document
11 Sec-Ch-Ua: "Chromium";v="89", ";Not A Brand";v="99"
12 Sec-Ch-Ua-Mobile: ?0
13 Accept-Encoding: gzip, deflate
14 Accept-Language: en-US,en;q=0.9
15 Connection: close
```

Request Response

Pretty Raw Render \n Actions

```
1  HTTP/2 302 Found
2  Date: Tue, 17 Aug 2021 13:34:18 GMT
3  Content-Type: text/html; charset=UTF-8
4  X-Powered-By: PHP/7.4.11
5  Expires: Wed, 11 Jan 1984 05:00:00 GMT
6  Cache-Control: no-cache, no-store, must-revalidate, max-age=0
7  X-Redirect-By: WordPress
8  Location: https://kommunitas.net/wp-login.php?redirect_to=https%3A%2F%2Fkommunitas.net%2Fwp-admin%2F&reauth=1
9  X-Litespeed-Cache-Control: no-cache
10 Alt-Svc: h3-27=":443"; ma=86400, h3-28=":443"; ma=86400, h3-29=":443"; ma=86400, h3=":443"; ma=86400
11 X-Turbo-Charged-By: LiteSpeed
12 Cf-Cache-Status: DYNAMIC
13 Expect-Ct: max-age=604800, report-uri="https://report-uri.cloudflare.com/cdn-cgi/beacon/expect-ct"
14 Report-To: {"endpoints":[{"url":"https:\/\/a.nel.cloudflare.com\/report\/v3?s=VmD0kZGY4iQDTrtETOPoJj9Y6%2FXA%2B8u%2BWaluFBwVxaROsuE00xZ2vDFS0Rg8TgotelX0pL3fxDSiXNtQ2trS3bKhd%2B08EFpuntB0t
15 Nel: {"success_fraction":0,"report_to":"cf-nel","max_age":604800}
16 Server: cloudflare
17 Cf-Ray: 68034772ce760186-SIN
```

References:

- https://wordpress.org/support/article/hardening-wordpress/

L6. Cookies with missing, inconsistent, or contradictory properties

Risk Rating: Low

Affected Functionality:

List of cookies with missing, inconsistent or contradictory properties:

- **https://kommunitas.net/wp-login.php**

  Cookie was set with:

  Set-Cookie: wordpress_test_cookie=WP%20Cookie%20check; path=/; secure

  This cookie has the following issues:

  - Cookie without SameSite attribute.

  When cookies lack the SameSite attribute, Web browsers may apply different and sometimes unexpected defaults. It is therefore recommended to add a SameSite attribute with an appropriate value of either "Strict", "Lax", or "None".

- **https://kommunitas.net/wp-login.php**

  Cookie was set with:

  Set-Cookie: wordpress_a473eb3168ed29b264e6a621608f1c30=%20; expires=Sat, 15-Aug-2020 23:59:53 GMT; Max-Age=0; path=/wp-admin; secure

  This cookie has the following issues:

  - Cookie without SameSite attribute.

  When cookies lack the SameSite attribute, Web browsers may apply different and sometimes unexpected defaults. It is therefore recommended to add a SameSite attribute with an appropriate value of either "Strict", "Lax", or "None".

- **https://kommunitas.net/wp-login.php**

  Cookie was set with:

  Set-Cookie: wordpress_sec_a473eb3168ed29b264e6a621608f1c30=%20; expires=Sat, 15-Aug-2020 23:59:53 GMT; Max-Age=0; path=/wp-admin; secure

kommunitas.net

This cookie has the following issues:

- Cookie without SameSite attribute.

When cookies lack the SameSite attribute, Web browsers may apply different and sometimes unexpected defaults. It is therefore recommended to add a SameSite attribute with an appropriate value of either "Strict", "Lax", or "None".

- **https://kommunitas.net/wp-login.php**

  Cookie was set with:

  Set-Cookie: wordpress_logged_in_a473eb3168ed29b264e6a621608f1c30=%20; expires=Sat, 15-Aug-2020 23:59:53 GMT; Max-Age=0; path=/; secure

  This cookie has the following issues:

  - Cookie without SameSite attribute.

  When cookies lack the SameSite attribute, Web browsers may apply different and sometimes unexpected defaults. It is therefore recommended to add a SameSite attribute with an appropriate value of either "Strict", "Lax", or "None".

- **https://kommunitas.net/wp-login.php**

  Cookie was set with:

  Set-Cookie: wp-settings-0=%20; expires=Sat, 15-Aug-2020 23:59:53 GMT; Max-Age=0; path=/; secure

  This cookie has the following issues:

  - Cookie without SameSite attribute.

  When cookies lack the SameSite attribute, Web browsers may apply different and sometimes unexpected defaults. It is therefore recommended to add a SameSite attribute with an appropriate value of either "Strict", "Lax", or "None".

- **https://kommunitas.net/wp-login.php**

  Cookie was set with:

Set-Cookie: wp-settings-time-0=%20; expires=Sat, 15-Aug-2020 23:59:53 GMT; Max-Age=0; path=/; secure

This cookie has the following issues:

- Cookie without SameSite attribute.

When cookies lack the SameSite attribute, Web browsers may apply different and sometimes unexpected defaults. It is therefore recommended to add a SameSite attribute with an appropriate value of either "Strict", "Lax", or "None".

- **https://kommunitas.net/wp-login.php**

  Cookie was set with:

  Set-Cookie: wordpressuser_a473eb3168ed29b264e6a621608f1c30=%20; expires=Sat, 15-Aug-2020 23:59:53 GMT; Max-Age=0; path=/; secure

  This cookie has the following issues:

  - Cookie without SameSite attribute.

  When cookies lack the SameSite attribute, Web browsers may apply different and sometimes unexpected defaults. It is therefore recommended to add a SameSite attribute with an appropriate value of either "Strict", "Lax", or "None".

- **https://kommunitas.net/wp-login.php**

  Cookie was set with:

  Set-Cookie: wordpresspass_a473eb3168ed29b264e6a621608f1c30=%20; expires=Sat, 15-Aug-2020 23:59:53 GMT; Max-Age=0; path=/; secure

  This cookie has the following issues:

  - Cookie without SameSite attribute.

  When cookies lack the SameSite attribute, Web browsers may apply different and sometimes unexpected defaults. It is therefore recommended to add a SameSite attribute with an appropriate value of either "Strict", "Lax", or "None".

- **https://kommunitas.net/wp-login.php**

kommunitas.net

Cookie was set with:

Set-Cookie: wp-postpass_a473eb3168ed29b264e6a621608f1c30=%20; expires=Sat, 15-Aug-2020 23:59:53 GMT; Max-Age=0; path=/; secure

This cookie has the following issues:

- Cookie without SameSite attribute.

When cookies lack the SameSite attribute, Web browsers may apply different and sometimes unexpected defaults. It is therefore recommended to add a SameSite attribute with an appropriate value of either "Strict", "Lax", or "None".

- **https://kommunitas.net/wp-login.php**

  Cookie was set with:

  Set-Cookie: wordpress_a473eb3168ed29b264e6a621608f1c30=%20; expires=Sun, 16-Aug-2020 01:08:27 GMT; Max-Age=0; path=/wp-admin; secure

  This cookie has the following issues:

  - Cookie without SameSite attribute.

  When cookies lack the SameSite attribute, Web browsers may apply different and sometimes unexpected defaults. It is therefore recommended to add a SameSite attribute with an appropriate value of either "Strict", "Lax", or "None".

- **https://kommunitas.net/wp-login.php**

  Cookie was set with:

  Set-Cookie: wordpress_sec_a473eb3168ed29b264e6a621608f1c30=%20; expires=Sun, 16-Aug-2020 01:08:27 GMT; Max-Age=0; path=/wp-admin; secure

  This cookie has the following issues:

  - Cookie without SameSite attribute.

  When cookies lack the SameSite attribute, Web browsers may apply different and sometimes unexpected defaults. It is therefore recommended to add a SameSite attribute with an appropriate value of either "Strict", "Lax", or "None".

kommunitas.net

- **https://kommunitas.net/wp-login.php**

  Cookie was set with:

  Set-Cookie: wordpress_logged_in_a473eb3168ed29b264e6a621608f1c30=%20; expires=Sun, 16-Aug-2020 01:08:27 GMT; Max-Age=0; path=/; secure

  This cookie has the following issues:

  - Cookie without SameSite attribute.

  When cookies lack the SameSite attribute, Web browsers may apply different and sometimes unexpected defaults. It is therefore recommended to add a SameSite attribute with an appropriate value of either "Strict", "Lax", or "None".

- **https://kommunitas.net/wp-login.php**

  Cookie was set with:

  Set-Cookie: wp-settings-0=%20; expires=Sun, 16-Aug-2020 01:08:27 GMT; Max-Age=0; path=/; secure

  This cookie has the following issues:

  - Cookie without SameSite attribute.

  When cookies lack the SameSite attribute, Web browsers may apply different and sometimes unexpected defaults. It is therefore recommended to add a SameSite attribute with an appropriate value of either "Strict", "Lax", or "None".

- **https://kommunitas.net/wp-login.php**

  Cookie was set with:

  Set-Cookie: wp-settings-time-0=%20; expires=Sun, 16-Aug-2020 01:08:27 GMT; Max-Age=0; path=/; secure

  This cookie has the following issues:

  - Cookie without SameSite attribute.

  When cookies lack the SameSite attribute, Web browsers may apply different and sometimes unexpected defaults. It is therefore recommended to add a SameSite attribute with an appropriate value of either "Strict", "Lax", or "None".

kommunitas.net

- **https://kommunitas.net/wp-login.php**

  Cookie was set with:

  Set-Cookie: wordpressuser_a473eb3168ed29b264e6a621608f1c30=%20; expires=Sun, 16-Aug-2020 01:08:27 GMT; Max-Age=0; path=/; secure

  This cookie has the following issues:

  - Cookie without SameSite attribute.

  When cookies lack the SameSite attribute, Web browsers may apply different and sometimes unexpected defaults. It is therefore recommended to add a SameSite attribute with an appropriate value of either "Strict", "Lax", or "None".

- **https://kommunitas.net/wp-login.php**

  Cookie was set with:

  Set-Cookie: wordpresspass_a473eb3168ed29b264e6a621608f1c30=%20; expires=Sun, 16-Aug-2020 01:08:27 GMT; Max-Age=0; path=/; secure

  This cookie has the following issues:

  - Cookie without SameSite attribute.

  When cookies lack the SameSite attribute, Web browsers may apply different and sometimes unexpected defaults. It is therefore recommended to add a SameSite attribute with an appropriate value of either "Strict", "Lax", or "None".

- **https://kommunitas.net/wp-login.php**

  Cookie was set with:

  Set-Cookie: wp-postpass_a473eb3168ed29b264e6a621608f1c30=%20; expires=Sun, 16-Aug-2020 01:08:27 GMT; Max-Age=0; path=/; secure

  This cookie has the following issues:

  - Cookie without SameSite attribute.

  When cookies lack the SameSite attribute, Web browsers may apply different and sometimes unexpected defaults. It is therefore recommended to add a SameSite attribute with an appropriate value of either "Strict", "Lax", or "None".

kommunitas.net

- **https://kommunitas.net/wp-login.php**

  Cookie was set with:

  Set-Cookie: wordpress_a473eb3168ed29b264e6a621608f1c30=%20; expires=Sun, 16-Aug-2020 01:11:10 GMT; Max-Age=0; path=/wp-admin; secure

  This cookie has the following issues:

  - Cookie without SameSite attribute.

  When cookies lack the SameSite attribute, Web browsers may apply different and sometimes unexpected defaults. It is therefore recommended to add a SameSite attribute with an appropriate value of either "Strict", "Lax", or "None".

- **https://kommunitas.net/wp-login.php**

  Cookie was set with:

  Set-Cookie: wordpress_sec_a473eb3168ed29b264e6a621608f1c30=%20; expires=Sun, 16-Aug-2020 01:11:10 GMT; Max-Age=0; path=/wp-admin; secure

  This cookie has the following issues:

  - Cookie without SameSite attribute.

  When cookies lack the SameSite attribute, Web browsers may apply different and sometimes unexpected defaults. It is therefore recommended to add a SameSite attribute with an appropriate value of either "Strict", "Lax", or "None".

- **https://kommunitas.net/wp-login.php**

  Cookie was set with:

  Set-Cookie: wordpress_logged_in_a473eb3168ed29b264e6a621608f1c30=%20; expires=Sun, 16-Aug-2020 01:11:10 GMT; Max-Age=0; path=/; secure

  This cookie has the following issues:

  -Cookie without SameSite attribute.

  When cookies lack the SameSite attribute, Web browsers may apply different and sometimes unexpected defaults. It is therefore recommended to add a SameSite attribute with an appropriate value of either "Strict", "Lax", or "None".

kommunitas.net

- **https://kommunitas.net/wp-login.php**

  Cookie was set with:

  Set-Cookie: wp-settings-0=%20; expires=Sun, 16-Aug-2020 01:11:10 GMT; Max-Age=0; path=/; secure

  This cookie has the following issues:

  - Cookie without SameSite attribute.

  When cookies lack the SameSite attribute, Web browsers may apply different and sometimes unexpected defaults. It is therefore recommended to add a SameSite attribute with an appropriate value of either "Strict", "Lax", or "None".

Description:

At least one of the properties of the following cookie causes the cookie to be invalid or incompatible with either a different property of the same cookie or with the environment in which the cookie is being used. Although this is not a vulnerability in itself, it will likely lead to unexpected behavior by the application, which in turn may cause secondary security issues.

Impact:

Cookies will not be stored, or submitted, by web browsers.

Solution:

Ensure that the cookies configuration complies with the applicable standards.

kommunitas.net

Proof of Concept:

Request

Pretty | Raw | \n | Actions

```
1  GET /wp-login.php?reauth=1&redirect_to=https://kommunitas.net/wp-admin/ HTTP/2
2  Host: kommunitas.net
3  Cookie: _ga=GA1.2.1270988368.1629172597; _gid=GA1.2.151874741.1629172597
4  Sec-Ch-Ua: "Chromium";v="89", ";Not A Brand";v="99"
5  Sec-Ch-Ua-Mobile: ?0
6  Upgrade-Insecure-Requests: 1
7  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
   Gecko) Chrome/89.0.4389.90 Safari/537.36
8  Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*
   ;q=0.8,application/signed-exchange;v=b3;q=0.9
9  Sec-Fetch-Site: none
10 Sec-Fetch-Mode: navigate
11 Sec-Fetch-User: ?1
12 Sec-Fetch-Dest: document
13 Accept-Encoding: gzip, deflate
14 Accept-Language: en-US,en;q=0.9
15 Connection: close
```

Request | Response

Pretty | Raw | Render | \n | Actions

```
1  HTTP/2 200 OK
2  Date: Tue, 17 Aug 2021 08:50:01 GMT
3  Content-Type: text/html; charset=UTF-8
4  X-Powered-By: PHP/7.4.11
5  Expires: Wed, 11 Jan 1984 05:00:00 GMT
6  Cache-Control: no-cache, must-revalidate, max-age=0
7  Set-Cookie: wordpress_test_cookie=WP%20Cookie%20check; path=/; secure
8  Set-Cookie: wordpress_a473eb3168ed29b264e6a621608f1c30=%20; expires=Mon, 17-Aug-2020 08:50:01 GMT; Max-Age=0; path=/wp-admin; secure
9  Set-Cookie: wordpress_sec_a473eb3168ed29b264e6a621608f1c30=%20; expires=Mon, 17-Aug-2020 08:50:01 GMT; Max-Age=0; path=/wp-admin; secure
10 Set-Cookie: wordpress_a473eb3168ed29b264e6a621608f1c30=%20; expires=Mon, 17-Aug-2020 08:50:01 GMT; Max-Age=0; path=/wp-content/plugins; secure
11 Set-Cookie: wordpress_sec_a473eb3168ed29b264e6a621608f1c30=%20; expires=Mon, 17-Aug-2020 08:50:01 GMT; Max-Age=0; path=/wp-content/plugins; secure
12 Set-Cookie: wordpress_logged_in_a473eb3168ed29b264e6a621608f1c30=%20; expires=Mon, 17-Aug-2020 08:50:01 GMT; Max-Age=0; path=/; secure
13 Set-Cookie: wordpress_logged_in_a473eb3168ed29b264e6a621608f1c30=%20; expires=Mon, 17-Aug-2020 08:50:01 GMT; Max-Age=0; path=/; secure
14 Set-Cookie: wp-settings-0=%20; expires=Mon, 17-Aug-2020 08:50:01 GMT; Max-Age=0; path=/; secure
15 Set-Cookie: wp-settings-time-0=%20; expires=Mon, 17-Aug-2020 08:50:01 GMT; Max-Age=0; path=/; secure
16 Set-Cookie: wordpress_a473eb3168ed29b264e6a621608f1c30=%20; expires=Mon, 17-Aug-2020 08:50:01 GMT; Max-Age=0; path=/; secure
17 Set-Cookie: wordpress_a473eb3168ed29b264e6a621608f1c30=%20; expires=Mon, 17-Aug-2020 08:50:01 GMT; Max-Age=0; path=/; secure
18 Set-Cookie: wordpress_sec_a473eb3168ed29b264e6a621608f1c30=%20; expires=Mon, 17-Aug-2020 08:50:01 GMT; Max-Age=0; path=/; secure
19 Set-Cookie: wordpress_sec_a473eb3168ed29b264e6a621608f1c30=%20; expires=Mon, 17-Aug-2020 08:50:01 GMT; Max-Age=0; path=/; secure
20 Set-Cookie: wordpressuser_a473eb3168ed29b264e6a621608f1c30=%20; expires=Mon, 17-Aug-2020 08:50:01 GMT; Max-Age=0; path=/; secure
21 Set-Cookie: wordpresspass_a473eb3168ed29b264e6a621608f1c30=%20; expires=Mon, 17-Aug-2020 08:50:01 GMT; Max-Age=0; path=/; secure
22 Set-Cookie: wordpressuser_a473eb3168ed29b264e6a621608f1c30=%20; expires=Mon, 17-Aug-2020 08:50:01 GMT; Max-Age=0; path=/; secure
23 Set-Cookie: wordpresspass_a473eb3168ed29b264e6a621608f1c30=%20; expires=Mon, 17-Aug-2020 08:50:01 GMT; Max-Age=0; path=/; secure
24 Set-Cookie: wp-postpass_a473eb3168ed29b264e6a621608f1c30=%20; expires=Mon, 17-Aug-2020 08:50:01 GMT; Max-Age=0; path=/; secure
25 X-Frame-Options: SAMEORIGIN
26 X-Litespeed-Cache-Control: no-cache
27 Vary: Accept-Encoding
28 X-Turbo-Charged-By: LiteSpeed
29 Cf-Cache-Status: DYNAMIC
30 Expect-Ct: max-age=604800, report-uri="https://report-uri.cloudflare.com/cdn-cgi/beacon/expect-ct"
31 Report-To: {"endpoints":[{"url":"https:\/\/a.nel.cloudflare.com\/report\/v3?s=3fCAX%2BNLJ5zgv6%2Bi5P2BDakEUpWFTaCsSYPBPTi8BLNoTTNjt%2BGsVxKHXLbHJ1HsW3n0fMTAIQPQ%2BmYGwWtb5C6JELhl9vyg%2
32 Nel: {"success_fraction":0,"report_to":"cf-nel","max_age":604800}
33 Server: cloudflare
34 Cf-Ray: 6801a7033e542eb6-SIN
```

References:

- https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Set-Cookie
- https://www.sjoerdlangkemper.nl/2017/02/09/cookie-prefixes/
- https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-rfc6265bis-05
- https://datatracker.ietf.org/doc/html/draft-west-first-party-cookies-07

Conclusion

Finally, I have completed the penetration & vulnerability test of the web application. These tests have been based on technology and known threats to date in this document. All safety issues discovered during this exercise have been analyzed and described in this report.

Please note that as technology and risks change over time, so will the vulnerabilities associated with the operation of the systems described in this report, as well as the steps required to reduce the exposure to such vulnerabilities.